Payment Card Data Handling Policy

POL-COMP-008 · Version 3.1 · Effective 2025-01-10

1. Purpose

The purpose of the Payment Card Data Handling Policy (POL-COMP-008) is to establish a framework for the secure handling, processing, and storage of payment card data within Acme Corp. This policy aims to protect sensitive cardholder information and ensure compliance with industry standards, including the Payment Card Industry Data Security Standard (PCI DSS).

2. Scope

This policy applies to all employees, contractors, and third-party service providers who have access to payment card data within Acme Corp. The systems involved in this policy include the Payment Gateway, Billing Service, Fraud Detection Engine, and Ledger DB.

3. Policy Statements

3.1 Data Handling

- The full card number (PAN) must never be written to logs, tickets, or chat.
- Card numbers are tokenized by the Payment Gateway before any other system sees them.
- The cardholder data environment includes the Payment Gateway, Billing Service, and Fraud Detection Engine.

3.2 Access Control

- Access to cardholder data is restricted to authorized personnel only, as defined in the Access Control Policy (POL-COMP-004).
- All users must authenticate themselves using strong credentials and adhere to the principle of least privilege.

3.3 Data Retention

- Cardholder data must be retained only as long as necessary to fulfill its intended purpose, in accordance with the Data Retention Policy (POL-COMP-001).
- Once the data is no longer needed, it must be securely deleted or anonymized.

3.4 Vulnerability Management

- Vulnerability scans of the cardholder data environment will be conducted quarterly to identify and remediate security weaknesses.

• Any vulnerabilities discovered must be reported and addressed in a timely manner to maintain the integrity of the cardholder data environment.

3.5 Compliance Assessment

• An annual PCI DSS assessment will be performed by a qualified assessor to ensure compliance with industry standards and regulations.

• Any findings from the assessment must be documented and remediated according to established timelines.

3.6 Incident Management

• Any suspected or confirmed security incidents involving payment card data must be reported immediately, following the procedures outlined in the Incident Response Policy (POL-COMP-003).

• The Incident Commander will oversee the response to any incidents and ensure that appropriate actions are taken.

3.7 Data Security

• All systems handling payment card data must implement necessary security controls, including encryption, access controls, and secure development practices as outlined in the Encryption and Key Management Policy (POL-COMP-005).

• Employees must adhere to the Acceptable Use Policy (POL-COMP-002) when accessing systems that process payment card data.

4. Roles and Responsibilities

• The owning team of each system involved in the cardholder data environment is responsible for implementing and maintaining security controls as specified in this policy.

• All employees and contractors must complete security training and adhere to the guidelines set forth in this policy.

• The on-call engineer is responsible for monitoring and responding to alerts concerning payment card data handling.

5. Exceptions

Any exceptions to this policy must be documented and approved by the designated authority. Exceptions will be considered only under specific circumstances that justify non-compliance, and must include a plan for mitigation of associated risks.

6. Enforcement

Violations of this policy may result in disciplinary action, up to and including termination of employment or contract. All employees and contractors are expected to report any suspected violations to their supervisor or the designated compliance officer.

7. Related Documents

- POL-COMP-001: Data Retention Policy
- POL-COMP-002: Acceptable Use Policy
- POL-COMP-003: Incident Response Policy
- POL-COMP-004: Access Control Policy